

END USER INFORMATION TECHNOLOGY GUIDELINES

Ver 1.0

**** This guidelines is an extract from Board adopted IT and Infosec Policy

Document name:	End user information technology guidelines
Prepared by:	Bhavesk Kumar
Reviewed by:	Kandarp Kant
Approved by:	Gaurav Sharma
Version #:	1.0
Effective Date:	27 October 2021

Table of Contents

Introduction	4
1. Purpose	4
2. Objective:	5
3. Applicability	5
4. Compliance	5
5. Guidelines Control.....	5
6. IT Strategy and Planning.....	5
7. IT organizational structure.....	8
8. Enterprise Architecture	9
9. Supplier Management	10
10. Business Continuity Planning and Disaster Recovery.....	11
11. Program & Project Management.....	13
12. Change Management	14
Organization of Information Security	15
Overview:	15
Information Security Control Objectives.....	16
1.A.1 Addressing Security in Third Party Agreements	17
1.A.2 Addressing Security When Dealing with Customers.....	17
2 Acceptable Usage Guidelines	18
A. General Use	18
B. Securing Proprietary Information	19
C. E-mail Usage	19
D. Internet Usage	20
E. Remote Access Usage	20
F. File Servers Usage	20
G. Printers Usage.....	21
H. Software Usage	21
I. External Storage Devices.	21
J. Prohibitive System and Network Activities	21
K. Incident Reporting	22
3 Access Control.....	22
3.A.1 User Access Management	22
3.A.2 User Registration	23
B. User Responsibilities	24

3.B.1	Password Use.....	24
3.B.2	Clear Desk and Clear Screen Guidelines	24
3.B.3	Secure Log-on Procedures	25
C.	Mobility & Remote Computing	25

Introduction

1. Purpose

The purpose of this document is to establish the Guidelines and direction encompassing all the strategic and operational areas of Information Technology and its use in Poonawalla Fincorp. Ltd. The IT Management Guidelines is backed by a set of Standards, Guidelines, Standard Operating Procedures (SOP) and Templates detailing each process and activities of each section of the Guidelines. A mapping of the documents is given in Annexure A.

The following table lists each IT Guidelines along with its stated purpose.

#	Guidelines	Stated Purpose
Policies related to Business - IT		
1	IT Strategy & Planning	To ensure that IT priorities and projects are in alignment with business priorities and are executed in a time bound manner with adequate funding to realize them.
2	Enterprise Architecture	To ensure that the IT supports the business requirements in a scalable, reliable, secure, efficient, and cost-effective manner.
3	Supplier Management	To ensure that PFL is able to procure the best-in-class technology products and services in an objective manner, while adhering to industry best practices.
4	Business Continuity Planning and Disaster Recovery	To protect business data in the event of disaster of any form and provide continuity of business in such events.
5	Program & Project Management	To ensure predictability of all IT projects on Time, Quality and Cost parameters
6	Change Management	To ensure each change has been adequately evaluated against impact on business, IT and Cost before being approved and implemented.

2. Objective:

The objective of the Information Technology Guidelines is to set the guiding principles for establishing IT operational procedures and at the same time to achieve Confidentiality, Integrity and Availability ("CIA") of information systems used by Users of Organisation.

3. Applicability

The Guidelines is applicable to all locations of Organisation including all IT assets, all IT processes, all business processes supported by IT and all employees, partners, casual workers and outsourcing partners of organisation (hereafter referred to as 'PFL GROUP' or 'PFL' in this document).

4. Compliance

All the employees, contractors and agency staff connected to Information Technology at PFL have to comply with this Guidelines. Any deviation to the Guidelines in respective areas must have prior approval of CIO / CTO. Any breach of this Guidelines shall be investigated and may result in the matter being treated as a disciplinary offence under and as per the code of conduct of the organisation.

5. Guidelines Control

In case of any changes/amendments in the IT strategies in line with the corporate strategies, Board Guidelines reviews and any other matter related to IT Governance, the Guidelines shall be reviewed and approved by Strategy Committee and shall be placed before the Board for approval.

6. IT Strategy and Planning

- a. **Purpose:** Purpose is to ensure that IT priorities and projects are in alignment with business priorities and are executed in a time bound manner with adequate funding to realize them.
- b. **Scope:** Scope of IT Strategy is to capture the Business Strategy of PFL at corporate level and functional levels and formulate an IT Strategy following a defined methodology as part of the Standard Operating Procedure.

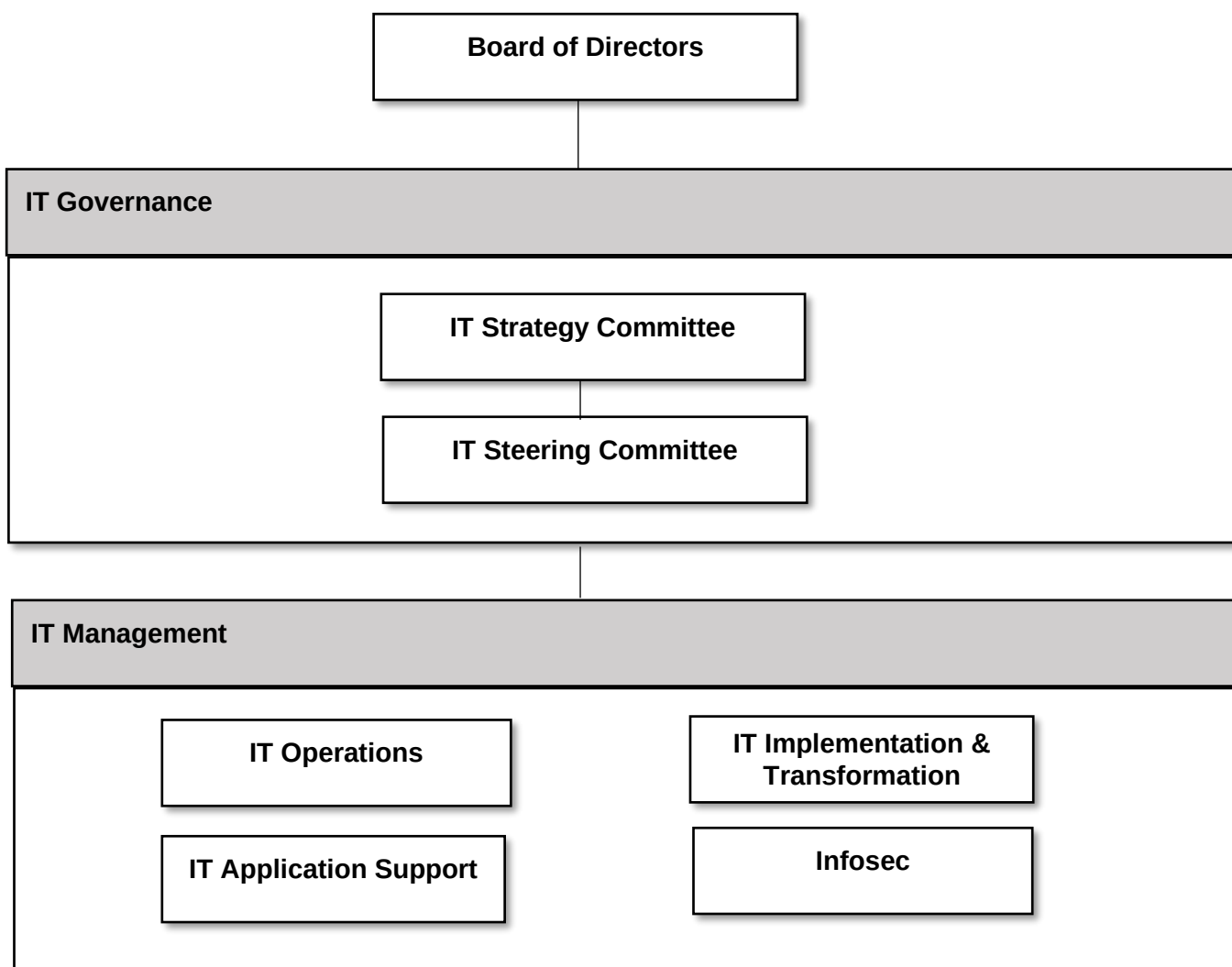
- c. **Outcome:** Outcome of IT Strategy and Planning exercise is to have a comprehensive IT Strategy document that captures the three-year view of IT along with the roadmap of IT projects and the budget that needs to be provisioned.
- d. **Stakeholders:** Primary ownership of IT Strategy and Planning lies with CIO / CTO / Head IT. The RACI Matrix has listed stakeholders. All IT Strategy and Planning artefacts must be signed off by the IT Strategy Committee (ITSC) to come in force. PFL's ITSC shall be appointed by the VC & MD.s
- e. **Guidelines Statements**
 - I. The IT Strategy must capture the business strategy of the Company at Corporate and Functional levels and relate them to the required IT capabilities.
 - II. PFL shall have a framework and methodology to create IT Strategy, which shall cover the following dimensions:
 - i. Enabler of Business Strategy
 - ii. Innovation
 - iii. Cost Efficiency
 - iv. Risk Mitigation
 - v. Regulatory compliances
 - III. Each new IT initiative must be supported by an appropriate business case; that includes business value, risks mitigated, customer impact, operational efficiency etc. in order to be part of the IT Roadmap.
 - IV. Investment in an IT project shall have clear segregation of Capital and Operational expenditure. This shall follow the Total Cost of Ownership framework and will be plotted over a five years' time horizon.
 - V. Confidentiality of Data: All budget information concerning price/rate assumed, size of project, vendors considered etc. is to be protected to ensure that it is not subject to misuse or passed on to third parties. Unauthorized disclosure of such information would be treated as breach of confidentiality, exposing the individual to disciplinary action.

- VI. To protect the Integrity of Information – Information shall remain accurate, error free and without unauthorized changes.
 - VII. To ensure the Availability of Information – authorized users shall have access to critical business information when required.
 - VIII. To ensure compliance to applicable laws, regulations, and guidelines.
 - IX. To ensure continuous delivery of critical services and products, which permits to recover its facility, information, and assets.
 - X. To ensure all Users are aware of their responsibilities towards protecting Information.
 - XI. To align with globally recognized standards for Information Security such as ISO 27001:2013.
 - XII. Frequency: The IT Strategy Committee shall meet at an appropriate frequency but not more than six months should elapse between two meetings.
- f. **Enforcement:** ITSC will monitor the adherence to IT Roadmap. Any unplanned IT initiative or project that may overshoot the approved IT budget, shall have to obtain ITSC approval.
- g. **Review:** IT Strategy and Planning is an annual exercise with a half yearly update to ITSC.

7. IT organizational structure

An IT organizational structure commensurate with the size, scale and nature of business activities carried out by the PFL with detailed IT portfolio, with Roles and responsibility shall be documented.

Refer IT Organization structure for more details.



8. Enterprise Architecture

- a. **Purpose:** Purpose of Enterprise Architecture Guidelines is to ensure that the IT supports the business requirements in a scalable, reliable, secure, efficient and cost-effective manner.
- b. **Scope:** Components of Enterprise Architecture comprises of ;
 - I. Business Architecture: Business applications supporting various business processes.
 - II. Information Architecture: Taxonomy of business entities supported by various application databases. Business Intelligence and Enterprise Data warehouse are part of this.
 - III. Application Architecture: Technical design and models powering business applications.
 - IV. Infrastructure Architecture: Hardware and network supporting the business applications.
 - V. Security Architecture: Hardware and software controls to protect business applications.
- c. **Outcome:** Outcome of Enterprise Architecture is a set of Enterprise Architecture documents and templates that capture all the five dimensions of Enterprise Architecture.
- d. **Stakeholders:** Primary ownership of Enterprise Architecture lies with CIO / CTO. Other Stakeholders shall include IT Leadership Team.
- e. **Guidelines Statements**
 - I. PFL shall have an Enterprise IT Architecture Framework supported by the Principles, Standards, Guidelines and Templates.
 - II. PFL shall ensure that various requirements are aligned across applications to avoid duplication or interference of functionality of one department with the others. This shall be depicted in a Process-Application Map as part of Business Architecture.
- f. **Enforcement:** CIO / CTO shall conduct assessments of IT landscape and projects as per checklist mentioned above.
- g. **Reviews:** Enterprise Architecture must be reviewed and updated on an annual basis. This will help baseline the constant change witnessed in Enterprise Architecture landscape.

9. Supplier Management

- a. **Purpose:** Purpose is to ensure that PFL is able to procure the best-in-class technology products and services in an objective manner, while adhering to industry best practices.
- b. **Scope:** This is applicable to all the activities of Vendor Management inclusive of vendor need identification, complete cycle of procurement and post procurement like vendor on-boarding, monitoring and exit. Subjects covered are:
 - i. IT assets related to hardware, software, networking or communication.
 - ii. Professional services in form of consulting, advisory, solution development, maintenance, and support or staff augmentation.
 - iii. Managed services from third parties like hosted or cloud-based solutions.
- c. **Outcome:** PFL shall establish and manage the supplier relationships so as to ensure quality of service provided by suppliers.
- d. **Stakeholders:** Primary ownership of IT Supplier Management lies with CIO / CTO / Head of IT or a role to whom either of these two are reporting to.
- e. **Guidelines Statements**
 - I. **IT Procurement Authority:** The CIO / CTO authorized delegate, shall be the primary authority for placing orders for IT hardware, software and services on behalf of PFL. For certain orders that are strategic in nature, an approval matrix shall be in place which will indicate the involvement and concurrence of other stakeholders
 - II. **Budget Applicability:**
 - 1. Budget Approval- Should be in place either as part of annual budget or alternatively a specific approval. However, emergency procurement can be done with post facto approval.
 - 2. There should be a separate approval matrix for non-budgeted expenditure, which need to be incurred due to changing business needs.
 - III. **Procurement Pre-Requisites:** Any IT procurement must be supported by the Procurement Note in the prescribed format as part of the templates to this Guidelines. The

procurement note shall be prepared by the person in charge of the concerned Technology Area

- IV. **Vendor Shortlist**: PFL shall define guidelines for identification of appropriate vendors. Industry references such as Gartner's Magic Quadrant and/or peer feedback shall be part of this.

f. **Enforcement**: Any suspected breaches of this Guidelines should, in the first instance, be reported to the CIO / CTO or the Head of the concerned IT portfolio

g. **Reviews**: The Guidelines must be reviewed at least on an annual basis.

10. Business Continuity Planning and Disaster Recovery

a. **Purpose**: Purpose is to protect business data in the event of disaster of any form and provide continuity of business in such events. Purpose is also to meet regulatory expectations on this aspect.

b. **Scope**: Scope of Business Continuity Planning is to conduct a Business Impact Analysis (BIA) for all business functions to identify the impact of a disaster on concerned business processes. BIA shall lead to the right sizing and strategy of DR site and capability.

c. **Outcome**: Outcome of BCP and DR Guidelines are DR Strategy and plan and BCP manual with identified steps in case of events.

d. **Stakeholders**: Primary ownership of BCP is with the concerned XCOM member for the related functional area; primary ownership of DR is with CIO / CTO / Head of IT or a role to whom either of these two are reporting to.

e. **Guidelines Statements**

i. **Business Continuity and Disaster recovery**:

- Information systems that are critical to the Organisation's business shall be identified through a formal BIA / Risk Assessment process and planned for continuity of operations in the event of disasters. Disaster Recovery Plan ("DRP"), in line with Organisation's Business Continuity plan, shall be formulated, maintained, tested, and implemented for such systems.

- The DRP and recovery strategies shall be derived from Business Continuity plan of respective units. The plan shall provide for appropriate safeguards to minimize the risk, cost, and duration of disruption to business processes caused by disasters.
- PFL shall ensure that disaster recovery capability is in place and tested sufficiently to ensure that ability of the company to provide service to its customers and secure its revenues can continue in the event of a disaster.
- Time to recover access to the application, and the allowable data loss that can be tolerated after a disaster shall be documented for all the critical applications.
- The aforementioned provisions shall be read in conjunction with Business Continuity and Disaster Recovery Guidelines of PFL, for the purpose of Disaster Recovery process to be carried out

II. **Business Impact Assessment:** A Business Impact Assessment (BIA) shall be carried out on annual basis to identify the critical process and their respective:

- a. Recovery Point Objective (RPO) – tolerance for any data loss at the DR Centre due to time lag of data replication.
- b. Recovery Time Objective (RTO) – time taken to restore the business process at DR site.

RPO and RTO have significant cost implications and shall be used to right size Disaster Recovery capability. PFL shall have a defined BIA template and the primary ownership of the filled-in BIA template will be with the respective Business Process Leaders.

III. **Information Security:** PFL shall follow the defined information security Guidelines to protect information during a disaster.

- f. **Enforcement:** Recovery testing shall be performed at least once a year for all business-critical applications
- g. **Reviews:** BCP and DR Guidelines shall be reviewed annually.

11. Program & Project Management

- a. **Purpose:** Purpose is to ensure predictability of all IT projects on Time, Quality and Cost parameters
- b. **Scope:** Scope of IT Program and Project Management Guidelines is all IT projects and Programs inclusive of IT Infrastructure, Business Applications, and Innovation Projects. A Program is a set of projects with common business or technology objectives. A project is a finite set of activities with a start and definite end date spanning a duration of at least six weeks.
- c. **Outcome:** Successful delivery of all project and programs
- d. **Stakeholders:** Primary ownership of Program and Project Management of all IT projects lies with CIO / CTO.
- e. **Guidelines Statements:**
 - I. **Project Sponsor:** Each Program and large project shall be sponsored by the respective Head of the Business, preferably at the XCOM level. They shall provide direction and resolve any issues related to company Guidelines or business strategy/direction.
 - II. **Project Ownership:** There shall be a Business Owner of the project who will request for the budget and create the Cost Benefit Analysis as applicable. This person shall also be responsible for documenting Requirements, User Acceptance Sign off and Rollout
 - III. **Steps/Activities to be followed in each project will be:**
 - Project Initiation
 - Resource Planning
 - Project Planning
 - Project Monitoring
 - Project Closure
- f. **Enforcement:** PFL should establish a steering committee, consisting of business owners, the development team and other stakeholders to provide oversight and monitoring of the progress of the project, including deliverables to be realized at each phase of the project and milestones to be reached according to the project timetable.

- g. **Reviews**: The Guidelines shall be reviewed and updated on annual basis.

12. Change Management

- a. **Purpose**: Purpose of Change Management Guidelines is to ensure each change has been adequately evaluated against impact on business, IT and Cost before being approved and implemented.

- b. **Scope**: Changes to organisation's IT assets including applications, servers and network devices shall be performed in a controlled manner to ensure that the risks associated with such changes are managed to an acceptable level. Critical changes shall be tested in non-production environment before deployment and ineffective changes shall be rolled back.

Approval for all Critical / High risk changes shall be done by Change Control Board.

For Medium / Low risk changes, which do not have wide impact/usage, the Change Control Board

functions shall be carried out within Application Owner's department or IT department.

- c. **Outcome**: Successful deployment of changes without any side effects or repeat issues.
- d. **Stakeholders**: Primary ownership of Change Management lies with CIO / CTO. Change Control Board (CCB) is the enforcing authority of change management.

e. **Guidelines Statements**

i. **Following procedure shall be followed for approval of a change request.**

- Prioritize responding to change proposals from business.
- Perform cost benefit analysis of the changes proposed.
- Assess the risks associated with the changes proposed.
- Change Control Board (CCB) has been established for all application groups to take decisions on changes to be implemented.

- For every change, a change request should be documented and shared with appropriate authorities for review.
- All change requests should be approved before implementation.
- All changes should be compliant with statutory and legal/regulatory requirements as applicable to PFL.

II. Implementation of Change

- Change should be implemented based on the implementation plan approved as part of change request.
- Post Implementation, review should be performed to confirm if the change is working as desired
- The changes shall be done in such a way that adverse incidents and disruption to services are minimized while maximizing value for the customers of PFL.
- The impact of change shall be periodically monitored and a report of the same shall be placed before the Board for its review.

III. Documentation of Change

- All Documents related to change request should be retained for audit purpose.

f. **Enforcement**: The CCB will be the enforcing authority for the changes.

g. **Reviews**: Change Management Guidelines shall be reviewed annually.

Organization of Information Security

Overview:

1. The Information Security (IS) Guidelines defines appropriate responsibilities, authority and relationships to manage information security in Poonawalla PFL Limited. and all its

group/associate /joint venture companies and subsidiaries (hereafter referred to as 'PFL' in this document).

2. The Information Security Guidelines establishes a security management framework for implementation within PFL. Hence, it is important that the programme is consistently implemented across PFL. This shall entail commitment from management and formulation of an information security governance structure to drive the Guidelines. Management shall provide overall direction to the programme, approve policies and procedures, assign the various roles, co-ordinate and review the implementation of the Guidelines.
3. IT Steering Committee (ITSgC) shall be formed comprising of Head- Information Security, CIO, CTO, and IT Leadership team. Representation, participation or involvement from Business and Support functions may be present as and when desired, basis any strategy, initiative, requirement or support required from either party.

Information Security Control Objectives

Information Security at Organisation. driven by the following objectives:

- Protection of information against unauthorized access by maintaining its confidentiality;
- Ensuring the integrity of information. Integrity relates to the accuracy and completeness of information as well as to its validity in accordance with business values and expectations;
- Ensuring the availability of information to those who are authorized and require it. Availability relates to information being available when required by the business process now and in the future. It also concerns the safeguarding of necessary resources and associated capabilities;
- Meeting the legal, regulatory, and legislative requirements.
- Imparting information security awareness training to all staff;
- Reporting and investigation of security breaches;
- Effective Role definition for all employees to avoid conflict in duties and areas of responsibility;
- Managing Information security risk by integrating Information security governance in the overall enterprise governance framework of the organization; and
- Ensuring Continual Improvement to the information security management system.

1.A.1 Addressing Security in Third Party Agreements

- a. The information security requirements of outsourcing the management and control of all or some of the PFL's information systems, applications, equipment, and network devices shall be addressed in a contract agreed between the third party and PFL.
- b. All third parties shall adhere to PFL's IS Guidelines.
- c. Applicable clauses pertaining to information security shall be identified by PFL and incorporated into the legal agreements while outsourcing any service/work to a third party.
- d. Third parties shall not outsource any work to subcontractors. If there is a business need, the requirement shall be approved through a valid business case and all liabilities applicable to the third party shall apply to the sub-contractors. PFL reserves similar rights (viz., audit) with the subcontractor as those with the third party. The third party shall be responsible to enforce PFL's IS Guidelines on its sub-contractors.
- e. Service levels and information security metrics as defined in the agreements shall be monitored and reported by third parties.
- f. Third parties shall be subject to independent reviews on a periodic basis for their compliance with PFL's Third Party Information Security requirements.
- g. Information Security Team along with Business Owner/Application owner shall ensure relevant training updates, DO's /Don't are communicated to Vendors.
- h. PFL shall have the right to continuously monitor and assess the service provider/vendor and its infrastructure, so that deficiencies, if any can be identified and necessary corrective measure can be taken immediately.
- i. PFL shall have the right to access all books, records and information relevant to the outsourced activity.
- j. PFL shall have the right to conduct audits on the service provider/vendor whether by its internal or external auditors, or by external specialists appointed to act on its behalf and to obtain copies of any audit or review reports and findings made on the service provider in conjunction with the services performed for PFL.
- k. Right for PFL or the regulator governing of PFL (e.g., RBI, SEBI) to audit the service provider or their sub-contractor to ensure compliance to contract and prevailing regulations/legislations.

1.A.2 Addressing Security When Dealing with Customers

- a. The information security requirements related to customers accessing PFL's information/information assets shall be identified by the relevant functional units, along with the ISD.

- b. The justification, requirements and benefits for customer access shall be evaluated to ensure the implementation of controls and safety of the organisational assets. The following factors shall be addressed prior to granting access to the customers:
- The level of access required for the customers and the list of users requiring access.
 - The contractual rights to monitor and revoke any activity related to PFL's information/information assets.
 - Respective liabilities of PFL and the customer.
 - The above-mentioned requirements shall be documented and signed by the customer and PFL. These requirements shall be incorporated in the contractual agreement with the customer.

2 Acceptable Usage Guidelines

Overview:

The guidelines outline the acceptable use of technology resources at PFL. These guidelines are intended to protect technology resources from various Information & Cyber threats. The guidelines define prohibitive activities for users including but not limited to employees, contractors and third-party personnel (hereinafter referred to as "users") that, if performed, can have serious consequences such as exposure to risks, compromise of information/information assets, information systems, applications, equipment and network devices, legal issues and may lead to a disciplinary action against the user

Description

A. General Use

Objective: To define the acceptable use of the following at PFL:

- Intellectual Property
- E-Mail
- Internet
- Chat rooms, Social Networking and Instant Messaging
- Remote access
- File servers
- Printers
- Software
- Systems and Network

B. Securing Proprietary Information

The following guidelines shall be adhered to in order to secure proprietary information at PFL:

- a. Users shall have no proprietary rights or interest in any idea, invention, design, technical or business innovation, computer program and related documentation, or work product (hereinafter referred to as “intellectual property”) developed by the user for PFL.
- b. Users shall acknowledge that all intellectual property developed or used during employment is a property of PFL.
- c. Any unauthorised distribution of proprietary or classified information including shall be prohibited and shall result in disciplinary action against the user.
- d. On termination of employment/contract, the information assets under user’s possession or under the user’s control that may contain sensitive information shall be returned to PFL

C. E-mail Usage

E-mail is a widely used medium for exchange of information between two or more individuals and for business communication; hence the usage of the e-mail shall be governed by PFL. The following sections provide guidelines to ensure that emails are used as an efficient mode of business communication and that the email services are not misused by the users.

- a. All messages generated by the e-mail system shall be considered the property of PFL.
- b. PFL reserves the right to monitor email use to ensure compliance with PFL’s Acceptable Usage Guidelines.
- c. The e-mail system shall be used for business purposes only. However, limited personal use of the e-mail systems may be allowed as long as it does not damage the information and/or reputation of PFL.
- d. The users shall not open attachments received from unknown senders, which may contain malware such as viruses, worms or Trojans.
- e. Transmitting any material that potentially contains viruses, Trojan horses, e-mail bombs or any other harmful or malicious program.
- f. Defaming, abusing, harassing, stalking, threatening or violating any legal and privacy laws.
- g. Forwarding official e-mails to personal e-mail accounts such as Gmail, Yahoo mail and Hotmail. Business related e-mails shall not be sent from a private e-mail account.
- h. Using e-mail in connection with non-business related surveys and contests, chain letters, junk e-mail, spamming, or unsolicited messages is prohibited.
- i. Sending mails to distribution list unless authorised.
- j. Do not send or forward any messages through PFL information systems that contain copyrighted content that is not the intellectual property of PFL.

- k. Do not use PFL information systems for the transmission of any type of unsolicited bulk electronic mail advertisements or commercial messages that are likely to trigger complaints from the recipients.

D. Internet Usage

- a. Access to the Internet shall be granted for business-related purposes only.
- b. PFL shall reserve the right to record and monitor internet usage. Any inappropriate use of the internet may result in a disciplinary action.
- c. The downloading of software onto PFL's system without approval is prohibited.
- d. Downloaded software may only be used under the terms of its license agreement.
- e. In case the information from the Internet is used for PFL business decisions, the integrity and the source of the information shall be verified. Additionally, care shall be taken not to violate any copyright laws when using information obtained from the Internet.
- f. Personal use of internet may be limited as long as it does not adversely affect PFL's activities. Users shall not post any derogatory or abusive content on the Internet as official communication from PFL.
- g. No official communication/ response from PFL shall be posted on the Internet unless it has been approved by appropriate authority.

E. Remote Access Usage

- a. The remote access shall be provided to the users based on approval and shall be limited to authorize personnel and for business related purposes.
- b. PFL reserves the right to refuse to extend remote access privileges to any user and may refuse or terminate remote access arrangement at any time.
- c. Special care shall be taken while using mobile computing devices to ensure that the organisational information stored thereon is not compromised.

F. File Servers Usage

- a. The access to the file servers shall be restricted to authorised personnel only. Appropriate role-based access rights shall be configured.
- b. Only business related data shall be stored on file servers.
- c. No personal data would be stored on file servers.

G. Printers Usage

- a. Printing of personal items such as photos and personal e-books shall be prohibited.
- b. Printed hard copies of sensitive information shall be protected and destroyed after use as per the Media Disposal Guidelines.
- c. It must be ensured that documents printed on the printer are collected immediately and not left on the printer.

H. Software Usage

- a. PFL provides users workstations or other mobile computing devices. All software required to maintain and to keep track of the workstations and mobile computing devices are installed on these devices and shall not be tampered with.
- b. PFL shall not support any non-standard system configurations and shall reserve the right to remove such systems from the network if it poses a security risk to PFL.
- c. Installation of any unauthorised or unlicensed software on the workstations shall be prohibited.
- d. Commercial software purchased by PFL shall be authorised for PFL use only and shall be utilised in accordance with contractual agreements and copyright laws.
- e. Making copies of copyright protected software and related documentation for personal use shall be prohibited, unless specifically authorised within the license agreement.
- f. PFL reserves the right to remove all unauthorised software and the personnel using such software shall be subject to disciplinary action.

I. External Storage Devices.

- a. Connecting any external storage device is not permitted. By default, access is restricted.
- b. Any external device /portable usage devices must be approved by Department Head and Infosec before same is connected to PFL Network.

J. Prohibitive System and Network Activities

- a. The introduction of malicious programs into the network or server (e.g., viruses, worms, Trojan horses, e-mail bombs).
- b. Usage of PFL information/information assets to engage in procuring or transmitting material that is in violation of sexual harassment or hostile workplace laws in the local jurisdiction.
- c. Making fraudulent offers of products, items, or services originating from any PFL account.
- d. Creating security breaches or disruptions in PFL's network communication. The security breaches include, but shall be not limited to, the following:
 - Accessing information to which the user is not an intended recipient.

- Logging into a server or account that the user is not authorised to access, unless these duties are within the scope of the job function.
 - Disruption includes but is not limited to, network sniffing, pinged floods, packet spoofing, denial of service and forged routing information for malicious purposes.
- e. Network monitoring, which intercepts data not intended for the employee's host, unless this activity is a part of the normal job function.
- f. Providing information about or lists of PFL employees or customers to parties outside PFL when not authorized to do so.

K. Incident Reporting

- a. It is the responsibility of all users to report any security incident they observe or suspect to the IT Helpdesk or ISD.

3 Access Control

Overview:

The Access Control Guidelines defines the controls that need to be implemented and maintained to protect information assets against unauthorised access that poses substantial risk to the organisation.

Unauthorised access to PFL information, impacting confidentiality and integrity of such information can lead to loss of reputation/regulatory non-compliance. In order to mitigate such risk PFL shall follow a uniform process for access control.

Access to information /information assets, information processing facilities, systems, applications equipment and network devices shall be restricted as per the valid business requirements, user's job responsibility and information security requirements. Formal procedures shall be in place to control the allocation of access rights.

Users shall be made aware of their responsibilities for maintaining effective access controls, particularly regarding the use of passwords and the security of user equipment.

3.A.1 User Access Management

Objective: To ensure authorised user access and to prevent unauthorised access to information systems.

3.A.2 User Registration

- a. Except for the publicly held information/publicly available information assets, the allocation of access rights to all other information/information assets, systems, applications, equipment, network devices and services shall be done in accordance with the User Access Management Process. The process shall encompass all stages in the life-cycle of user access, from the initial registration of new users to the final de-registration of users who no longer require access to information systems, applications and equipment.
- b. Every user shall be provided with login credential (a single unique user ID and password) to access PFL's information/information assets, information systems, applications, equipment and network devices.
- c. All user IDs on information/information assets, information systems, applications, equipment and network devices shall be created as per standard and identifiable nomenclature.
- d. Unique system user ID's shall be created. Use of Generic IDs for the purpose of interactive login shall not be permitted.
- e. Every system where a user ID is created, modified and deleted shall have the capability to generate an audit trail of these events. This audit trail shall follow PFL audit logging requirements.
- f. Formal Approval process shall be followed for providing access to all employees, contractors and third-party personnel. This access shall be used for legitimate business purposes and shall be removed when no longer necessary.
- g. All information/information assets, information systems, applications, equipment and network devices shall be configured with strong and effective password management controls.
- h. Accounts that access Restricted or Confidential data shall be reviewed semi-annually, using a documented business process. The review process shall verify that an on-going process is in place to ensure that employees who have left Organisation no longer have active accounts and those unnecessary entitlements have been removed when roles have changed.
 - a. For the transferred users (changes in job responsibilities, functional units, PFL legal entities, functions/and or geography within PFL), the existing user access rights shall be revoked and provided access as per the new role, basis formal approval
 - b. User IDs shall be disabled in the case of inactivity for a period of over at least 30 days. This may vary depending on the need and may vary for different applications or systems.
 - c. User IDs shall be disabled at the end of LWD / end of contract.
 - d. User IDs shall be deleted after 180 days of inactivity or after deactivation post LWD.

B. User Responsibilities

Objective: To prevent unauthorised user access, and compromise or theft of information and information processing facilities.

3.B.1 Password Use

- a. For all information systems, applications, equipment and network devices, any system generated password provided to the users shall be changed after the first login.
- b. Passwords shall never be shared or revealed to anyone other than the authorized user.
- c. Users shall minimize the use of fixed passwords in any computer files, such as logon scripts or computer programs,
- d. Users shall keep their user IDs and corresponding passwords confidential and refrain from sharing them with others.
- e. All PFL information systems, applications, equipment and network devices shall be configured to ensure that passwords typed are masked, suppressed or otherwise obscured such that unauthorized parties may not be able to observe and/or subsequently recover them.
- f. Passwords shall not be written down or stored in clear text.
- g. Users shall ensure that the passwords are kept confidential and shall not be shared or disclosed to anyone including the IT Help Desk.
- h. If a temporary password has been provided to the user, it shall be changed immediately upon the next logon. (It should be the part of System requirement rather than User Responsibility)

3.B.2 Clear Desk and Clear Screen Guidelines

- a. A clear desk Guidelines for papers and a clear screen Guidelines for information processing facilities shall be adopted in order to reduce the risks of unauthorised access, loss of and damage to information during and outside normal working hours.
- b. It is the responsibility of all employees and third-party staff to adhere to the below mentioned requirements:
 - Where appropriate, paper and physical media shall be stored in suitable locked cabinets and/or other forms of secure closets when not in use, especially outside working hours.
 - Outside of regular working hours, all employees shall clear their desks and working areas of all sensitive or valuable information.

3.B.3 Secure Log-on Procedures

- a. The access to the operating systems of information systems, equipment and network devices shall be restricted through a defined log-on procedure and access controls.
- b. The log-on procedure shall ensure that
 - A message/banner shall be configured wherever possible to warn users that unauthorised use is prohibited, and that legal action shall be taken against offenders.
 - The system shall not disclose any system related information unless the user is authenticated.
 - Direct root/super user/administrator login shall be disabled or restricted to be used on certain occasions which shall be authorised by appropriate authority.
 - All the operating system/applications shall be configured to log in users with unique user IDs.
 - A secure login shall ensure that, if it is a remote login, it shall be through a secure protocol (SSH, HTTPS).
- c. The number of unsuccessful logon attempts shall be limited to 5, post which account shall be locked out.

C. Mobility & Remote Computing

Objective: To ensure security controls and processes are as effective when work from home (WFH) is provided to users during a prolonged disaster or crisis situation.

- a. Employees having company provided/ owned assets shall be authorized to connect remotely to the network and access internal applications / data.
- b. All required security controls on company provided assets shall be implemented and managed to always ensure effectiveness.
- c. Employees using BYOD shall not be provided direct access to the network. They may continue to access Web facing & Cloud applications accessible on the Internet.
- d. Data download restrictions or similar controls shall be implemented for users using BYOD devices.
- e. Users, on their part shall be responsible and take appropriate measures to ensure that their personal devices are always secured; by using Anti-virus, patch updates, genuine software, etc. (For more information, refer to the BYOD Guidelines).
- f. Users shall take appropriate steps to prevent any type of compromise or breach of company information residing on their devices.
- g. The same level of access privileges shall be provided when user connects from outside the network.
- h. Authorized access to network, applications or data shall be provided post successful identification and authentication of the user and their authorized device.

- i. Encryption shall be mandatory for all laptops (including Third Party users), subject to laws and legal restrictions.
- j. The technology used for mobile services by Organisation shall ensure confidentiality, integrity, availability, and authenticity and shall provide for end-to end encryption.

Arial 12, Line spacing 1.5